SQL INJECTION - LOGIN BYPASS

PortSwigger Web Security Academy Lab Report

Prepared by: Sofia

Focus: Web Application Security / WAPT Foundations

Platform: PortSwigger Web Security Academy

Lab: SQL injection vulnerability allowing login bypass

IqraSec Academy - WAPT Internship - Phase 1

1. Executive Summary

The login function of this lab builds its SQL query with my username and password. I logged in as administrator without knowing the password.

2. Lab Information

Platform	PortSwigger Web Security Academy
Room / Lab	SQL injection vulnerability allowing login bypass
Primary Domain	Web Application Security
Purpose	Foundational WAPT practice
Completion	Completed - lab solved
Link	https://portswigger.net/web-security/sql-injection/lab-login-bypass

3. Learning Objectives

- Understand how SQL injection can bypass authentication.
- Log in as the administrator user.

4. Vulnerability / Concept

If the login query is built with string concatenation, a quote in the username closes the string and I can add my own SQL. A comment sequence then removes the password check.

5. Testing Approach

In the username field I entered **administrator'--** and any text as the password. The quote closes the username value and -- comments out the password condition, so the query only checks the username. The application logged me in as administrator and the lab was solved.

6. Evidence

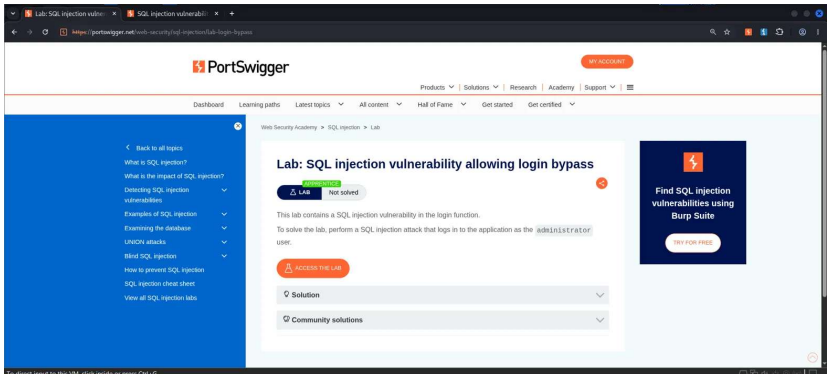


Fig 1 - Lab description.

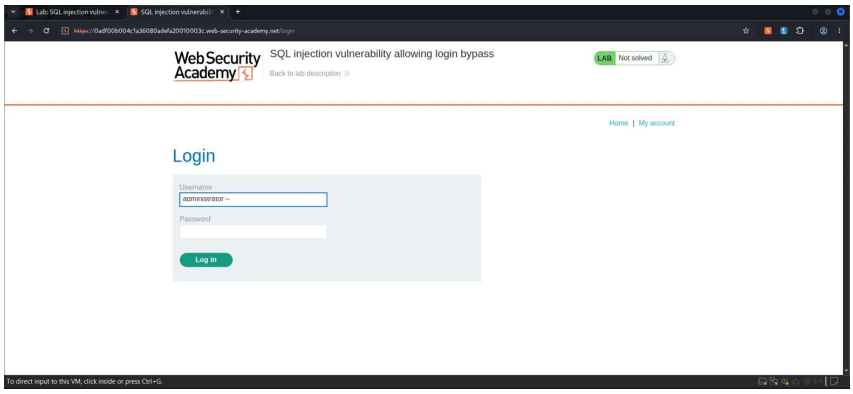


Fig 2 - Payload typed in the username field.

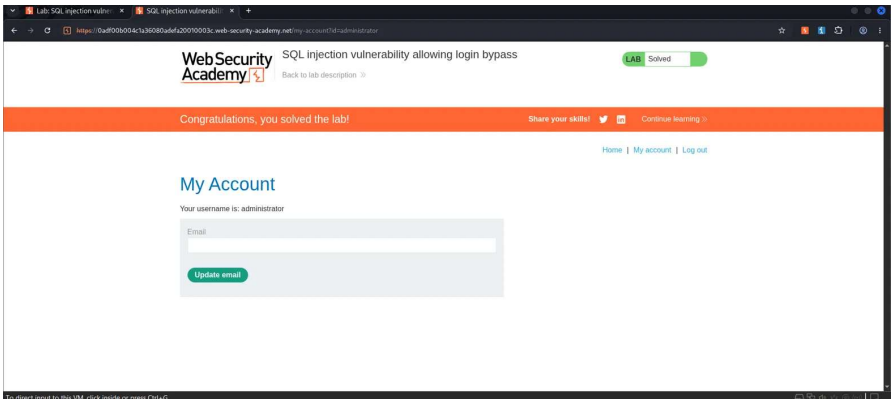


Fig 3 - Logged in as administrator, lab solved.

7. Impact

An attacker can log in as any user, including administrators, without a password.

8. Remediation

- Use prepared statements for login queries.
- Store passwords hashed and compare them in code, not in the SQL string.
- Add rate limiting and monitoring on login.

9. Key Security Takeaways

- Login forms are also SQL queries and can be injectable.
- Authentication must never rely on string-built queries.

10. Skills Practiced

Area	**Practical understanding gained**
Authentication bypass	SQL injection in a login form
Payloads	Quote and comment sequence

11. What I Would Explore Next

I will study other authentication vulnerabilities such as weak passwords, brute force and broken session handling.

12. Conclusion

This lab proved how dangerous an injectable login form is, because one line gives full administrator access.
Completion status: Completed - lab solved.

13. References

PortSwigger Web Security Academy: https://portswigger.net/web-security/sql-injection/lab-login-bypass